

1주차: 개발 · 오픈소스 공급망

이현지



수박겉핥기



AXIOS 공급망 해킹. 새벽에 무슨 일이 있었던 걸까

조회수 23만회 • 3개월 전



Normaltic Place

매 주 화요일 저녁! 9시~!!! 해킹 이야기를 듣는 시간!!! :D [편집] : 코코넛 [*] With Normaltic (강연, 방송 섭외 문의) normaltic's Instagram ...

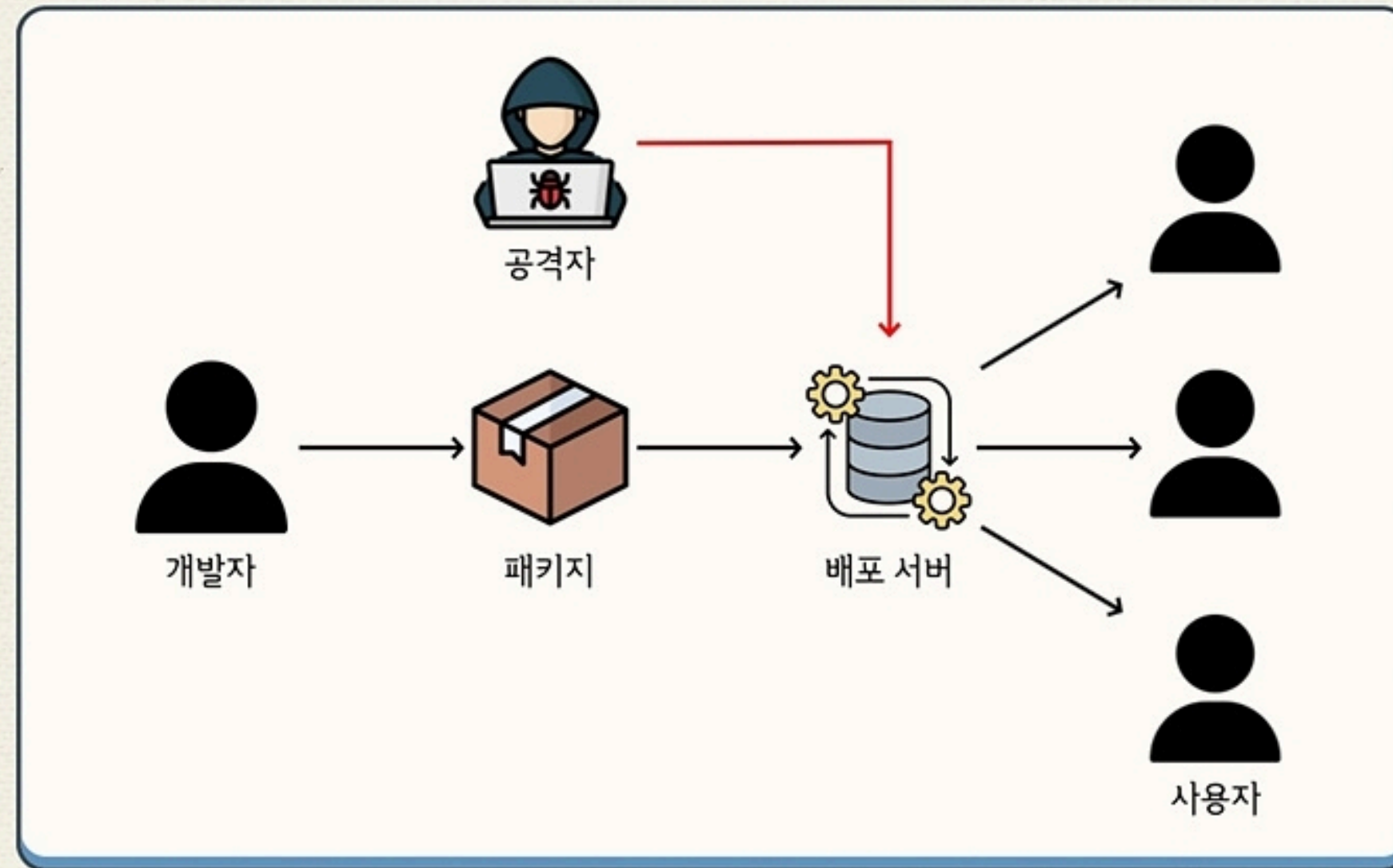
◆ 요약 개발자들이 흔히 사용하는 패키지인 엑시오스에서 발생한 관리자 계정 해킹과 그로 인한 악성 코드 유포 사건을 다룹니다....

<https://youtu.be/kLPXLC3pVrs?si=smelfHtoB2dn3fS2>

공급망 보안이란?

공급망 공격이란?

공급망 공격이란?



공격자가 기업의 소프트웨어 설치 및 업데이트 배포 과정에 침입해
정상 소프트웨어인 것처럼 꾸민 악성 소프트웨어를
사용자 기기에 설치하는 방식이다.

■ 공격 유형 및 사례

공급망 공격은 단기간에 큰 피해를 초래할 수 있고, 매년 발생하는 주요 공격 중에서도 발생빈도 상위에 속하고 있다. 해커들은 일반적으로 APT(지능형 지속 공격) 및 피싱 공격을 통해 소프트웨어 공급업체를 먼저 공격한 뒤, 내부망에 있는 소프트웨어 배포 서버 파일을 변조하는 방식을 이용한다. 또한, 오픈소스/라이브러리 취약점을 발견해 이를 악용하는 등 다양한 방법으로 공급망을 공격하고 있다.

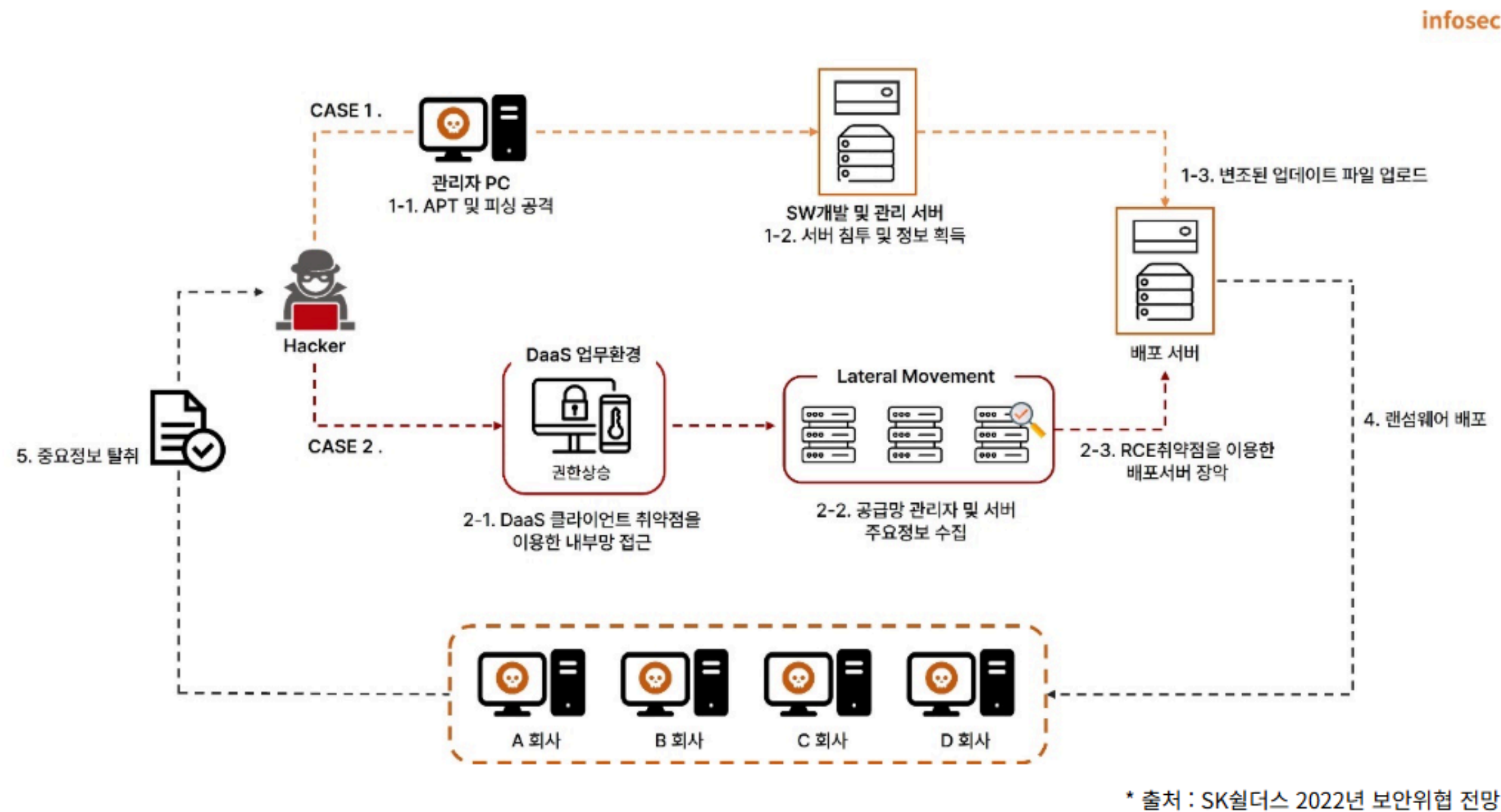
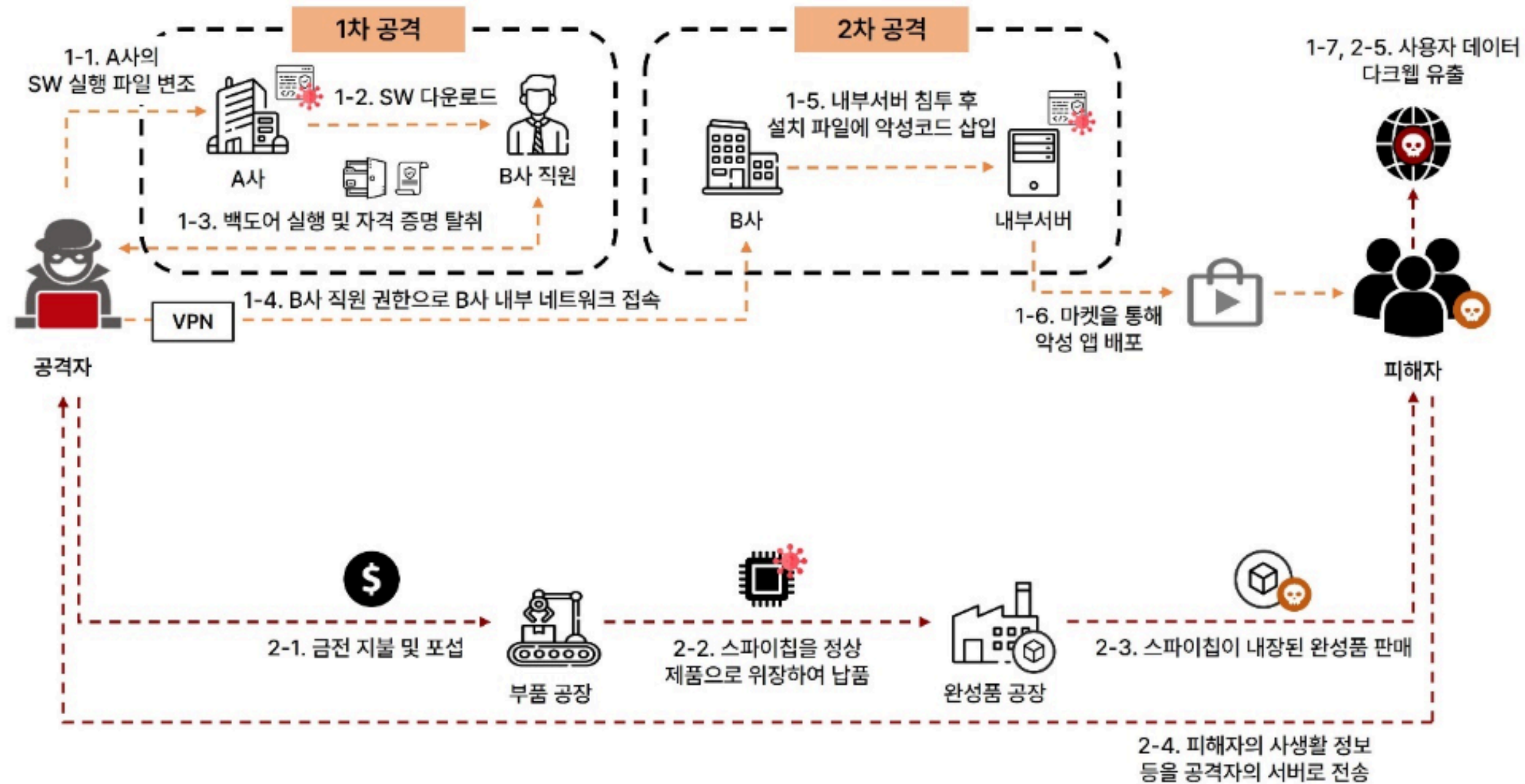


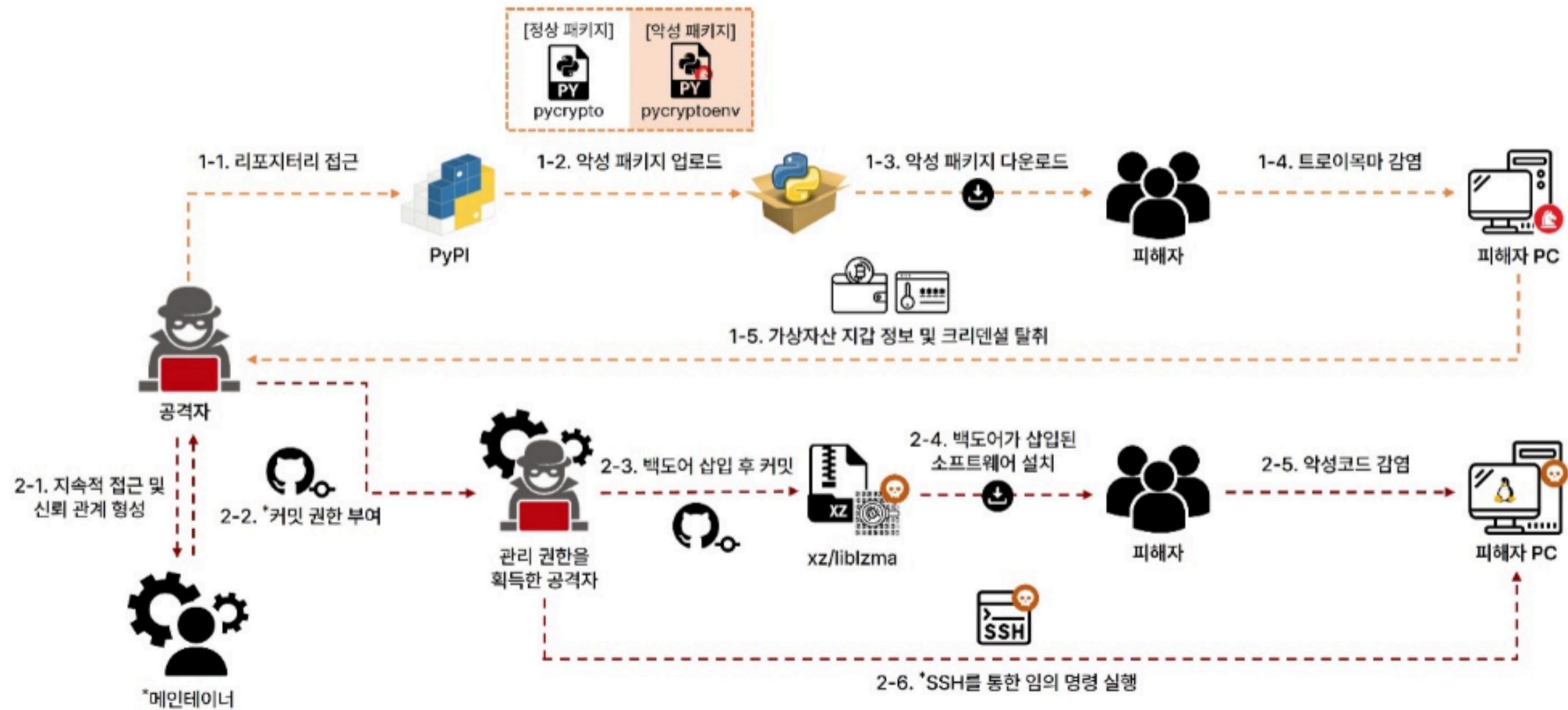
그림 2. 공급망 공격 방식



* 출처 : EQST 2023 상반기 보안 트렌드 리포트

그림 3. 확정된 공급망 공격 시나리오

3CX 직원이 소프트웨어 제공업체 트레이딩 테크놀로지스에서 악성코드가 삽입된 X_Trader 프로그램을 내려받으면서 해당 직원의 PC가 악성코드에 감염됐다. 공격자는 3CX 직원의 PC 권한을 탈취한 뒤 자격 증명을 악용해 3CX 빌드 서버에 침투했고, 3CX S/W에 멀웨어를 삽입했다. 변조된 소프트웨어는 공식 홈페이지를 통해 설치 파일로 전 세계 각국에 배포되었다.



* 출처 : SK윌더스 2024년 상반기 보안트렌드

그림 4. PyPI(Python Package Index) 커뮤니티를 통한 공급망 공격

Python 라이브러리인 ‘pycrypto’와 유사한 ‘pycryptoenv’, ‘pycryptoconf’를 패키지 이름으로 사용하거나, 또는 ‘pycrypto’와 같이 사용자 오타 실수를 이용하는 공격

SolarWinds · 3CX

공급망 보안 사고

- **SolarWinds(2020):** 공격자들이 Orion IT 모니터링 소프트웨어 업데이트에 악성 코드를 삽입하여 수천 개의 민간 기업 및 정부 기관을 침해했습니다.
- **3CX(2023):** 3CX 데스크톱 앱은 합법적으로 서명된 VoIP 소프트웨어 업데이트가 트로이목마화되어 다단계 악성코드를 배포하는 유사한 표적 공급망 침해를 겪었습니다.  www.crn.com +2

공격은 코드 밖에서도 일어난다
정상 소스여도 빌드 서버가 침해되면
악성 산출물이 배포될 수 있다

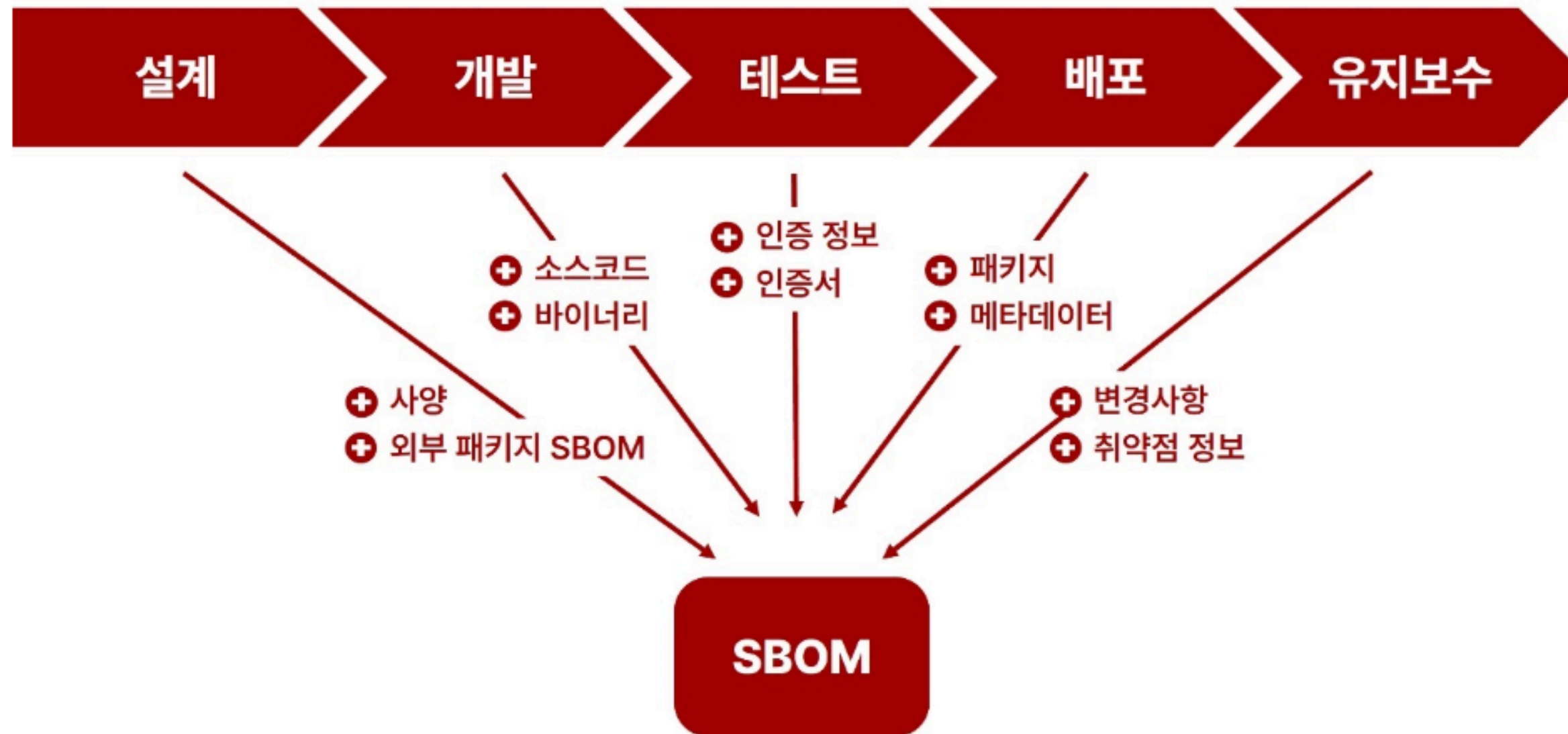
무엇이 들어왔고

어디까지 영향을 주는가?

공급망 보안?

■ 대응 방안

infosec



* 출처 : 한국인터넷진흥원

그림 5. SBOM(Software Bill of Materials)의 체계적인 관리 방법

공급망 전주기에 보안 내재화

기획·설계 → 개발 → 검토 → 빌드 → 테스트
→ 배포 → 운영 → 취약점 대응 → 지원 종료

SBOM

Software Bill of Materials

명세서

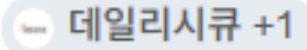
영향 범위를 빠르게 찾는 것

취약점 발표 → 검색 → 제품 식별 → 대응 우선순위

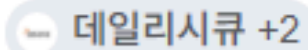
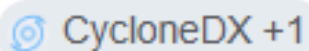
VEX

SBOM: 무엇이 들어 있는가

VEX: 그 취약점이 실제로 영향을 주는가

SBOM(소프트웨어 자재 명세서)과 VEX(취약점 악용 가능성 교환)은 **소프트웨어 공급망 보안을 강화하기 위한 상호보완적 핵심 도구**입니다. **SBOM은 소프트웨어에 포함된 모든 부품 목록을 보여주고, VEX는 그 부품의 취약점이 실제로 위험한지 알려줍니다.** 

SBOM과 VEX의 주요 개념

- **SBOM (Software Bill of Materials):**
 - 소프트웨어에 쓰인 오픈소스, 라이브러리, 코드가 무엇인지 목록화.
 - 구성 요소 파악 및 자산 관리 목적. 
- **VEX (Vulnerability Exploitability eXchange):**
 - 발견된 취약점이 실제 제품 환경에서 악용 가능한지 여부를 전달하는 표준 포맷.
 - 취약점이 있어도 실행되지 않거나 영향이 없는 경우를 구분해 불필요한 조치 방지. 

공급망 보안 3단계 프로세스

SBOM → VDR → VEX 연계 흐름



소프트웨어 명세

Software Bill of Materials

소프트웨어 구성요소
전체 목록 작성
라이브러리, 버전, 라이선스



취약점 발견

Vulnerability Disclosure Report

SBOM 기반
취약점 스캔 수행
CVE, CVSS 점수 매핑



영향도 분석

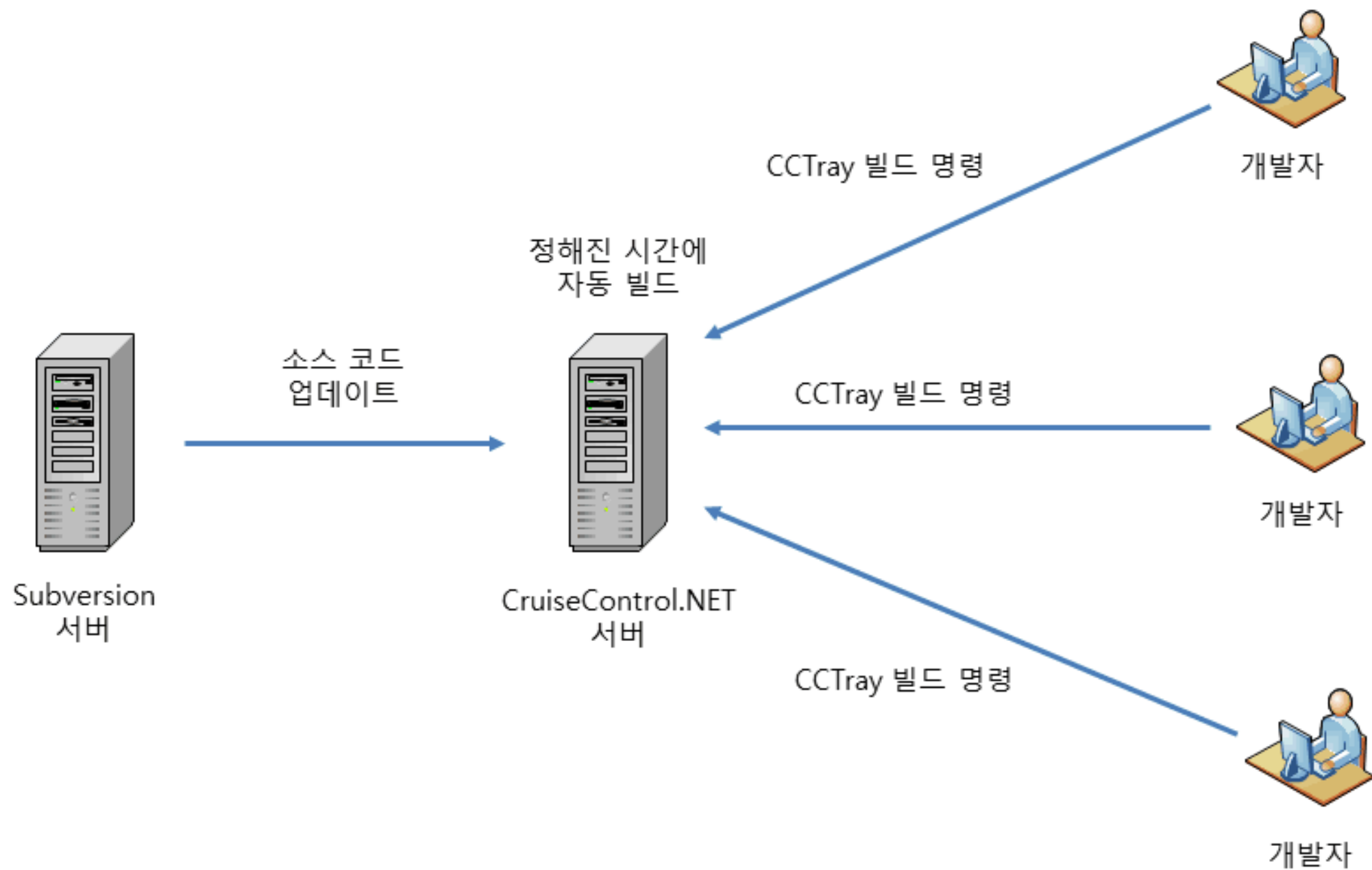
Vulnerability Exploitability Exchange

실제 영향 여부 판단
조치 우선순위 결정
영향없음/조치완료 표시

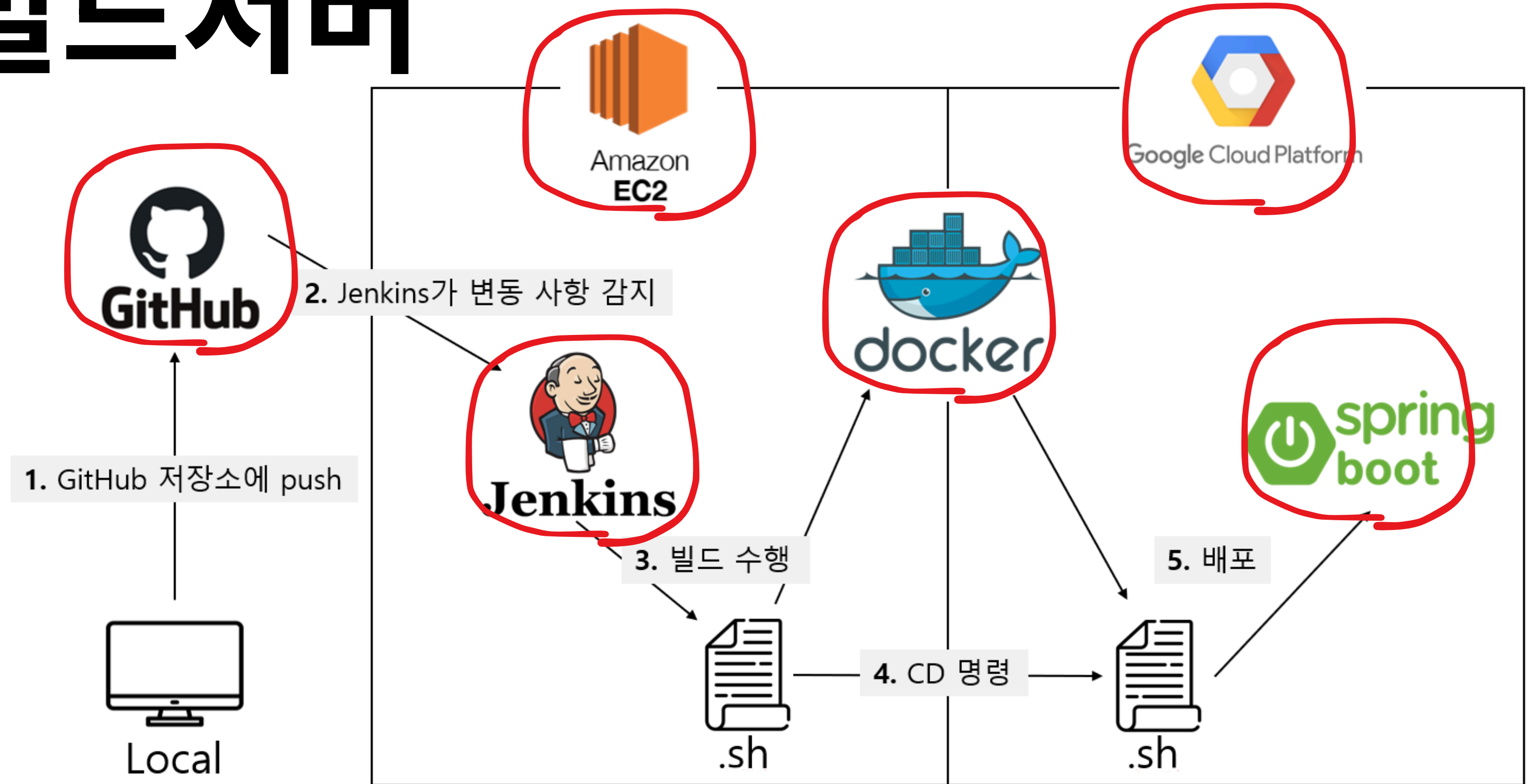
핵심 포인트

- ✓ 빌드 시 자동으로 SBOM 생성
- ✓ 취약점 DB와 실시간 연동
- ✓ 보안팀의 전문적 판단 필요
- ✓ 고객 및 감독기관에 투명성 제공

빌드서버



빌드서버



소프트웨어 공급망 보안 도구 핵심 정리

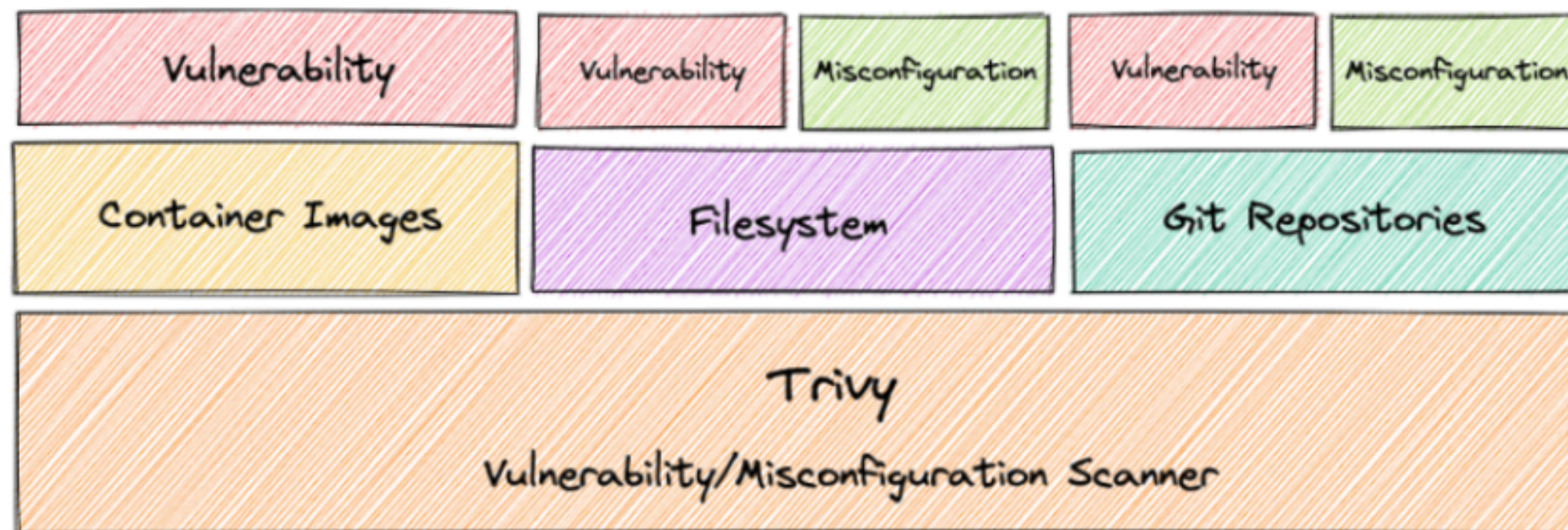
- **Trivy:**
 - 컨테이너 이미지, 파일 시스템, Git 저장소, Kubernetes 설정 등의 취약점(CVE), 설정 오류, 시크릿(비밀 정보)을 탐지하는 종합 오픈소스 보안 스캐너 
- **Syft:**
 - 컨테이너 이미지와 파일 시스템에서 패키지 및 종속성을 식별하여 표준 형식(SPDX, CycloneDX 등)의 소프트웨어 자재 명세서(SBOM)를 생성하는 특화 도구  ManuscriptLink +1
- **Cosign:**
 - Sigstore 프로젝트의 일부로, 컨테이너 이미지와 파일 및 SBOM 같은 아티팩트를 암호화 방식으로 서명하고 검증하여 무결성을 증명하는 도구  Open Policy Agent +2
- **OPA (Open Policy Agent):**
 - Kubernetes(Gatekeeper) 등 다양한 시스템에서 배포 및 운영 전반의 보안 정책과 거버넌스 규칙을 코드로 정의하고 강제하는 범용 정책 검증 엔진  secure-pipelines.com +1

이 도구들을 **CI/CD 파이프라인에 연동하는 방법**이나 **특정 도구의 상세 사용 명령어**가 필요하시면 말씀해 주세요.

Trivy

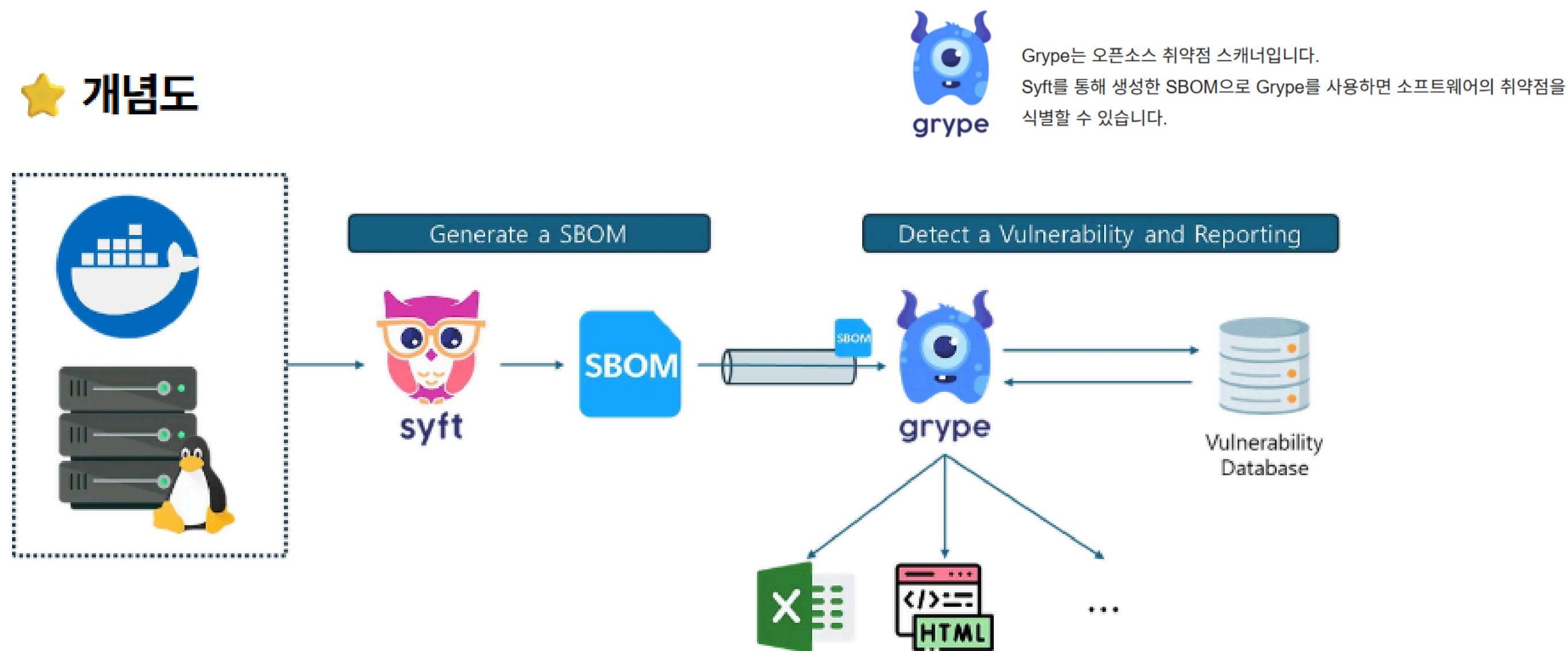
Trivy 소개

Trivy(트리비)는 취약점을 간단히 스캔할 수 있는 도구다. 컨테이너 이미지, 파일 시스템 및 Git 리포지토리의 취약점, 미설정 구성 문제에 대한 다양한 진단을 제공한다. OS 패키지(알파인, RHEL, CentOS 등)와 언어별 패키지(Bundler, Composer, npm, yarn 등)의 취약점을 탐지한다. 또한 테라폼, Dockerfile 및 Kubernetes와 같은 IaC(코드) 파일로 인프라를 스캔하여 배포를 공격 위험에 노출시키는 잠재적 구성 문제를 검색하는 기능도 포함되어 있다. 바이너리를 설치하거나 컨테이너를 사용하는 등 다양하고도 간단한 방법으로 취약점을 진단할 수 있다.

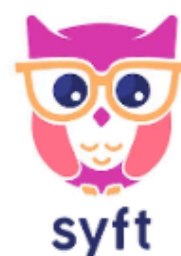


Syft

★ 개념도



Gype는 오픈소스 취약점 스캐너입니다.
Syft를 통해 생성한 SBOM으로 Gype를 사용하면 소프트웨어의 취약점을 식별할 수 있습니다.



Syft는 SBOM(Software Bill of Materials)을 생성하는 CLI 도구입니다.
참고로 컨테이너(OCI, Docker and [Singularity](#)) 및 리눅스 배포판을 대상으로 SBOM을 생성할 수 있으며, 현재 Windows 환경은 지원하지 않습니다.

Cosign

Cosign은 OCI 컨테이너 이미지와 소프트웨어 부산물을 안전하게 서명하고 검증하기 위한 [Sigstore](#) 프로젝트의 핵심 도구입니다. 소프트웨어 공급망의 무결성을 보장하며, 주요 기능과 사용법은 다음과 같습니다.  [GitHub](#) +3

주요 기능

- **컨테이너 서명:** 컨테이너 이미지와 파일에 디지털 서명을 생성합니다.
- **키리스 서명(Keyless):** 일회용 키와 OIDC 인증을 통해 복잡한 키 관리 없이 서명합니다.
- **서명 검증:** 저장된 서명을 확인하여 변조 여부를 점검합니다.  [GitHub](#) +4

컨테이너에 서명하고 해당 서명을 레지스트리에 저장합니다.

`@sha256:...` 이미지에 서명할 때는 태그()가 아닌 다이제스트()를 기준으로 서명해야 한다는 `:latest` 점에 유의하세요. 그렇지 않으면 의도하지 않은 항목에 서명하게 될 수 있습니다!

공개 키를 사용하여 컨테이너를 검증합니다.

공기가 차단된 환경에서 컨테이너를 검증합니다.

참고: 이 부분은 더 이상 최신 정보가 아닙니다.

참고: 대부분의 검증 워크플로는 TUF 저장소에서 서비스 키를 주기적으로 요청해야 합니다. 공개 자산 인스턴스를 사용하여 서명을 격리된 환경에서 검증하려면 프로덕션 TUF 저장소에서 [신뢰할 수 있는 루트](#) 파일을 가져와야 합니다. 이 파일의 내용은 예고 없이 변경될 수 있습니다. TUF를 사용하지 않는 경우, 격리된 환경에서 이 파일의 최신 버전을 유지하기 위한 자체적인 메커니즘을 구축해야 합니다.

신원 기반 블롭 서명 및 검증

키리스 블롭 서명(`cosign sign-blob` 키 없이 `--key`)을 사용하고 예상 서명자 ID와 비교하여 검증하십시오.

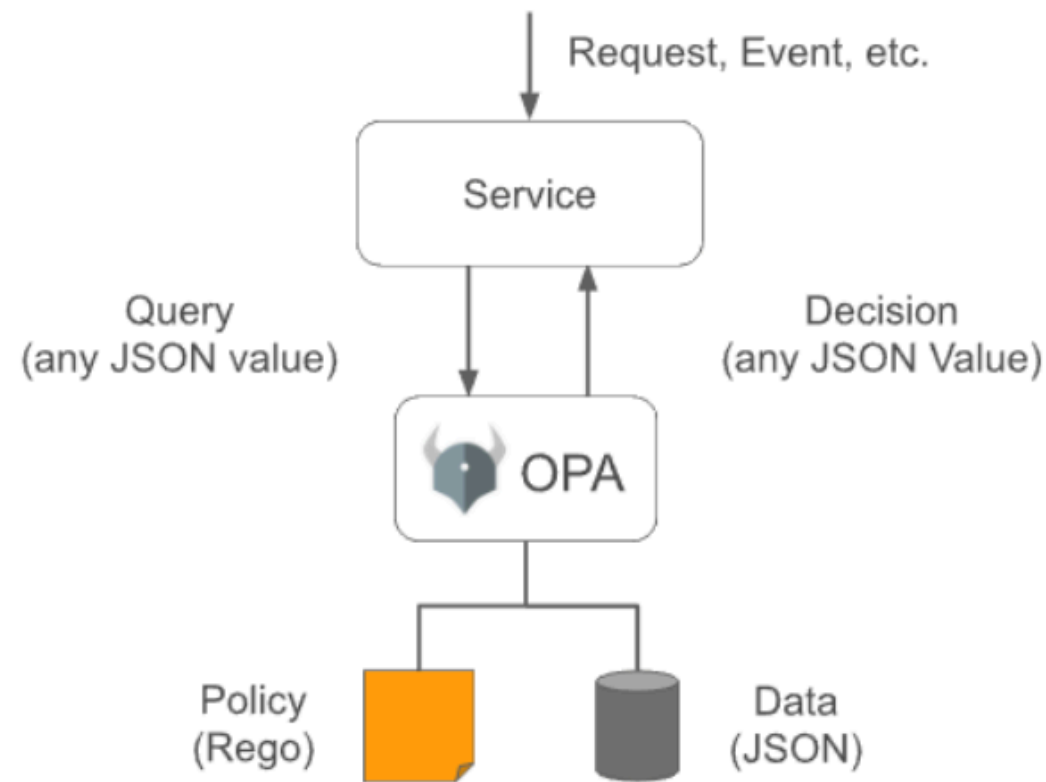
OPA

가상환경 정의 및 입력데이터 생성

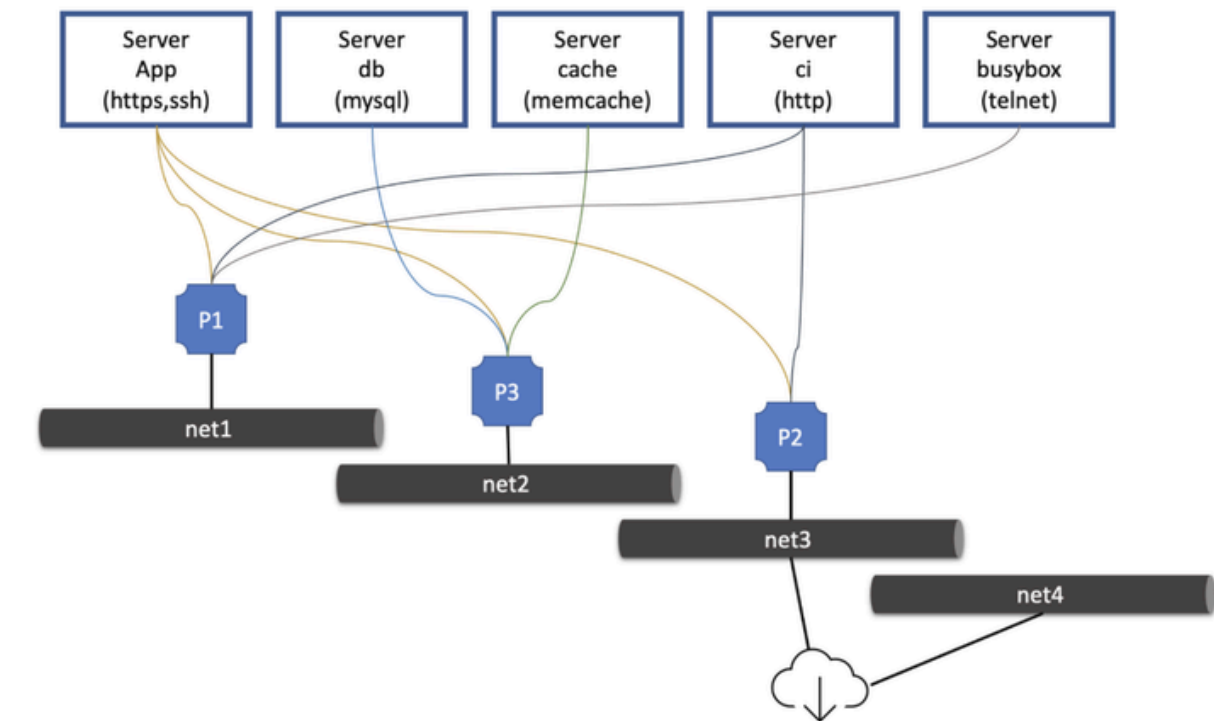
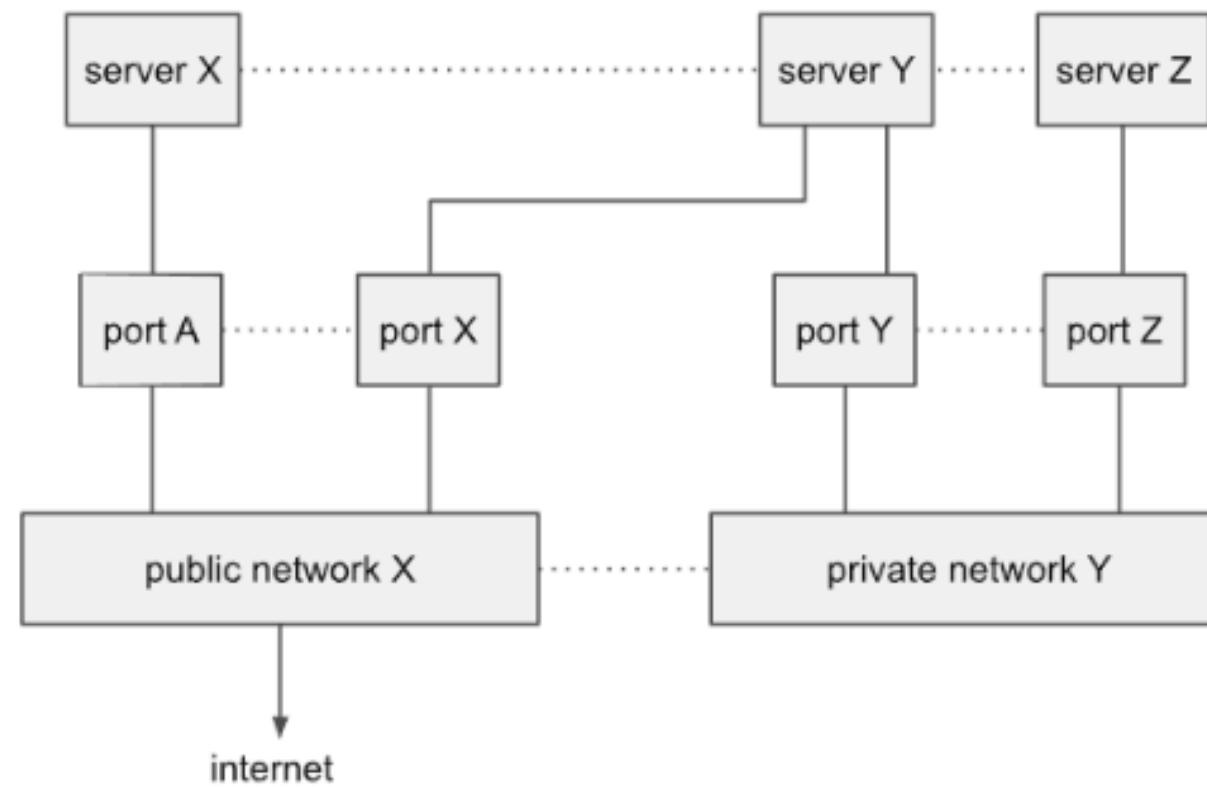
본 단락에서는 입력데이터를 만드는 구체적인 예를 보여준다. 다음 그림과 같은 시스템이 있다고 가정하자.

1. 0 개 이상의 프로토콜을 받는 서버들이 존재 (X,... Y, Z..)
2. 공용이나 사설망에 서버들을 연결하는 네트워크 (public, private)
3. 네트워크에 서버를 연결시키는 포트 (A, ... X, Y,... Z)

동작방식



<https://www.openpolicyagent.org/>



OPA는 정책 및 데이터에 대한 질의를 평가하여 정책의 결정을 돌려준다. 여기에서 질의(Query)와 결정(Decision)은 json으로 표현하면 어떤 것이든 포함할 수 있으며 이에 따라 매우 큰 확장성을 갖는다.

https://github.com/aquasecurity/trivy

 **trivy** Public

Watch 218

Fork 560

Star 37.1k

main

29 Branches

187 Tags

Go to file

Add file

Code

 **lxcjxhx** and **DmitriyLewen**

refactor(alpine): remove type assertion when reading ...

9321f90 · 1 hour ago

4,152 Commits

 .github	ci: create release branch with the App token to bypass the m...	3 weeks ago
 .vex	fix(vex): add CVE-2025-66564 as not_affected into Trivy VEX fi...	7 months ago
 brand	style: update band logos (#5968)	2 years ago
 ci	chore: update the rpm download Update (#9202)	last year
 cmd/trivy	feat: add documentation URL for database lock errors (#9531)	10 months ago
 contrib	fix(report): don't produce trailing comma in gitlab.tpl links arr...	2 months ago
 docs	feat(vex): discover OpenVEX in generic in-toto OCI referrers (...)	yesterday
 e2e	test: add end-to-end testing framework with image scan and ...	last year
 examples	feat: replace TinyGo with standard Go for WebAssembly mod...	last year
 helm/trivy	ci(helm): bump Trivy version to 0.72.0 for Trivy Helm Chart 0.2...	29 days ago
 integration	Merge commit from fork	last month
 internal	feat(vex): native discovery of VEX documents stored as OCI ar...	last week
 magefiles	chore: add schema id (#10969)	last week

About

Find vulnerabilities, misconfigurations, secrets, SBOM in containers, Kubernetes, code repositories, clouds and more

trivy.dev

containers

devsecops

docker

go

golang

hacktoberfest

iac

infrastructure-as-code

kubernetes

misconfiguration

security

security-tools

vulnerability

vulnerability-detection

vulnerability-scanners

Readme

Apache-2.0 license

Code of conduct

Contributing

Security policy

Activity

Custom properties

37.1k stars

<https://www.linkedin.com/pulse/understanding-supply-chain-security-open-source-regina-nkenchor-c6vwc/>

오픈소스 소프트웨어의 공급망 보안 이해하기

악성 패키지: 또 다른 주요 위험은 악성 패키지의 유입입니다. 공격자는 관리자의 계정을 탈취하거나 타이포스쿼팅(typosquatting)과 같은 기법을 통해 오픈소스 패키지에 악성 코드를 삽입할 수 있습니다. 타이포스쿼팅은 개발자가 실수로 잘못된 패키지를 다운로드하도록 유도하기 위해 정상적인 패키지와 유사한 이름으로 악성 패키지를 생성하는 행위입니다. 이러한 악성 패키지가 프로젝트에 통합되면 데이터를 유출하거나 백도어를 삽입할 수 있습니다.

- **위험 :** 악성 패키지는 유해한 작업을 실행하거나 민감한 데이터를 탈취하여 소프트웨어의 무결성을 손상시킬 수 있습니다.
- **완화 방안 :** 패키지 서명을 사용하고 신뢰할 수 있고 검증된 소스에서만 패키지를 설치하도록 엄격한 종속성 정책을 구현하십시오. Sigstore와 같은 도구를 사용하면 투명성을 확보하고 프로젝트에 포함되기 전에 패키지의 진위 여부를 확인할 수 있습니다.

CI/CD 파이프라인 침해: 지속적 통합/지속적 배포(CI/CD) 파이프라인은 코드 빌드, 테스트 및 배포 프로세스를 자동화하는 현대 소프트웨어 개발의 필수적인 부분입니다. 그러나 이러한 파이프라인은 공격자들의 주요 표적이기도 합니다. 파이프라인이 침해되면 악성 코드가 최종 사용자에게 배포될 수 있으며, 때로는 몇 달 동안 탐지되지 않을 수도 있습니다.

솔라윈즈 공격에서 공격자들은 회사의 빌드 시스템을 해킹하여 정상적인 소프트웨어 업데이트에 악성코드를 삽입했습니다. 이렇게 삽입된 악성코드는 정부 기관과 주요 기업을 포함한 수천 명의 고객에게 배포되었습니다.

- **위험성 :** 공격자가 CI/CD 파이프라인을 침해할 경우, 빌드 과정 중에 코드를 변조하여 악성 소프트웨어를 광범위하게 유포할 수 있습니다.
- **완화 방안 :** 다단계 인증(MFA), 코드 서명 및 엄격한 접근 제어 정책을 통해 CI/CD 파이프라인을 보호하십시오. in-toto와 같은 도구를 사용하면 빌드 프로세스의 무결성을 추적하여 무단 변경이 발생하지 않도록 할 수 있습니다.

2. 종속성 관리 개선: 효과적인 종속성 관리는 공급망 위험을 완화하는 데 매우 중요합니다. **Snyk, OWASP Dependency-Check, Sonatype Nexus**와 같은 도구는 알려진 취약점에 대한 종속성을 지속적으로 모니터링하고 업데이트 또는 패치가 있을 때 개발자에게 알림을 보낼 수 있습니다.

- **조치 :** 소프트웨어 스택의 오래된 종속성을 정기적으로 감사하고 취약점이 공개되는 즉시 종속성을 업데이트하십시오.

4. CI/CD 파이프라인 보호: **CI/CD 파이프라인을 보호**하는 것은 빌드 및 배포 단계에서 악성 코드가 유입되는 것을 방지하는 데 매우 중요합니다. 엄격한 접근 제어를 시행하고, 다단계 인증(MFA)을 사용하며, 빌드 결과물에 코드 서명을 적용하면 파이프라인을 보호할 수 있습니다.

조치 : **in-toto**와 같은 도구를 사용하여 빌드 프로세스의 무결성을 검증하고 신뢰할 수 있는 코드만 프로덕션 환경에 배포되도록 하십시오.

오픈소스 분야에서 최근 발생한 공급망 공격 사례

1. 솔라윈즈 공격

개요: 2020년 12월에 발견된 SolarWinds 공격은 최근 역사상 가장 중요한 사이버 스파이 사건 중 하나로, 소프트웨어 공급망에 내재된 취약성을 보여줍니다.

2. 이벤트 스트림 손상

개요: Node.js 애플리케이션에서 널리 사용되는 패키지인 event-stream 라이브러리는 2018년 말 프로젝트 관리 책임자가 바뀐 후 악성 코드가 삽입되어 보안에 취약해졌습니다.

3. 의존성 혼동 공격

개요: 2021년, 보안 연구원 알렉스 비르산은 패키지 관리자가 종속성을 해결하는 방식을 악용하는 "종속성 혼란"이라는 새로운 유형의 공격을 시연했습니다.

5. RubyGems 악성 패키지

개요: 2021년, 악성 패키지가 RubyGems에 업로드되는 사례가 여러 차례 발생하면서 패키지 관리 시스템의 취약점이 드러났습니다.

4. 코드코프 침해

개요: 2021년 초, 소프트웨어 프로젝트의 코드 커버리지를 측정하는 데 널리 사용되는 도구인 **Codecov**에서 대규모 데이터 유출 사고가 발생했습니다.

사건 상세 내용: 공격자들은 CI/CD 환경에서 코드 커버리지 보고서를 업로드하는 데 사용되는 **Codecov의 bash 업로더를 해킹**했습니다. 이 도구를 조작하여 공격자들은 여러 조직의 CI 시스템에서 민감한 환경 변수를 추출할 수 있었습니다.

이번 침해로 **API 키 및 인증 토큰과 같은 중요 정보가 노출될** 가능성이 생겼습니다.

자동화 및 AI 기반 위협 탐지

자동화는 대규모 공급망 보안 문제를 해결하는 데 핵심적인 역할을 할 것입니다. AI 기반 위협 탐지 시스템은 코드베이스, 종속성 및 빌드 파이프라인을 지속적으로 모니터링하여 취약점과 잠재적 공격을 실시간으로 식별합니다. 머신러닝 모델은 알려진 익스플로잇과 새롭게 등장하는 위협에 대한 방대한 데이터 세트로 학습되어 코드의 악의적인 패턴이나 공급망 전반의 비정상적인 활동을 사전에 탐지할 수 있게 됩니다.

- **자가 복구형 공급망** : 미래의 인공지능 기술 발전은 시스템이 취약점을 감지할 뿐만 아니라 자동으로 패치하고 손상된 부품을 안전한 버전으로 교체하는 자가 복구형 공급망을 가능하게 할 수 있습니다.
- **예측 분석** : AI 도구는 공급망 위험이 실제 위협으로 발전하기 전에 이를 식별하기 위해 예측 분석을 점점 더 많이 활용할 것입니다. 악용되는 취약점 유형의 추세를 분석함으로써 조직은 위험도가 가장 높은 구성 요소를 우선적으로 보호할 수 있습니다.

해야 할 부분

1. 쿠버네티스

2. npm

3. Trivy

4. 과거 공급망 위협 관련 이슈들

추가 공부 더 필요 하다 생각했음

방향성

1. SBOM은 너무 많음
2. CI/CD 방향성 좋아보임
3. 공부 더 해야함

앞으로 어떻게 해야할까?

1. 공부할 시간이 조금 부족했음 Y? 공급망에 대해 알아가느라 그거에 시간을 할애함
2. 다들 개발을 좋아하고 원해하는 것 같으니 개발 관련한 부분으로 기동잡고 가면 좋을 듯
3. 쿠버네티스 CI/CD 관련해서 가면 클라우드 & 네트워크 공급망까지 포함 가능할 듯
4. 거기에 AI 기능을 추가하면
5. 공급망이라는 주제에 클라우드 네트워크 AI가 싹 첨가가 됨
6. 뒷사람 발표가 어떻게 될지는 모르겠지만
7. 관찬은 중심 주제가 있다면 그걸 잡고 나아가는 방향도 매우 좋아보임

다음시간에는?

1. 홍서가 한 실습

2. 이걸 디벨롭할 방향성에 대하여

3. 스터디의 이유는 공급망 보안에 대해 알고싶기때문

4. CI/CD 에서 CD 관계에서보다는 CI 단계에서

5. CI 쿠버네티스를 파야할거같은데?

6. 현업에서 쿠버네티스를 안쓰는 곳을 본적이 없음

7. 방향성이 아직 뚜렷하지 않아서 이번주 실습은 하지말고 CI랑 쿠버네티스를 좀 파보는
방향으로 가고 좀 자주 만나서 많이 못알아내도 만나서 대화를 자주하면좋을듯?

8.

선웅 - 행위기반 탐지도구 최신 동향

현지 - CI/쿠버네티스 에 대하여 알아보기

현조 - CI/비인간 자격증명

효빈 - 공급망 공부 시작!

홍서 - 쿠버네티스 디깅깅.....